

Disaster Recovery & Business Continuity Plan

Aligned to NIST SP 800-34

SecurityGroup101 | Enterprise GRC Program

Prepared By: Maxine Jones, GRC Analyst | Reviewed By: Disaster Recovery Coordinator

Version 1.0 | Classification: Confidential – Internal Use

1. Purpose and Objectives

This plan defines the processes required to restore critical fintech services and maintain essential business operations following disruptive events, including ransomware attacks, physical infrastructure failures, and combined scenarios. Objectives are to restore critical financial and customer-facing services within defined RTO/RPO targets, protect the confidentiality, integrity, and availability of financial and customer data, maintain alignment with GLBA, PCI DSS, and FFIEC expectations, and enable coordinated recovery across cloud and on-premises environments.

2. Recovery Tiers

Recovery prioritization is based on Annualized Loss Expectancy (ALE), regulatory impact, and business dependency, as established in the Quantitative Risk Assessment.

Tier	Targets	Systems
Tier 1 – Critical	RTO $\leq$ 24 hrs / RPO $\leq$ 1–4 hrs	Customer data platforms, employee workstations required for operations, payment processing systems
Tier 2 – High	RTO $\leq$ 72 hrs / RPO $\leq$ 24 hrs	Financial records and reporting systems, backup infrastructure, proprietary financial analytics applications
Tier 3 – Moderate	RTO $\leq$ 7 days / RPO $\leq$ 48–72 hrs	Non-critical cloud storage, development environments, non-critical database servers, email, public website

3. Disaster Scenario

The plan is designed around a combined flooding and ransomware event: flooding renders primary facilities inaccessible and disrupts on-premises systems while ransomware simultaneously impacts cloud-based customer data and financial systems, requiring customer-facing services to be temporarily suspended to contain further damage.

4. Recovery Strategy

Activation: The Disaster Recovery Coordinator declares a disaster event, the DR team is activated with roles confirmed, and Incident Response and DRP procedures execute in parallel.

Containment and Assessment: Affected systems and network segments are isolated, compromised credentials revoked, and the scope of compromise — including data encryption and integrity — is assessed.

Restoration Sequence: Tier 1 assets are restored first from off-site, immutable backups, with employee workstations rebuilt from trusted baselines and payment systems validated in a secure recovery environment, before Tier 2 and Tier 3 assets are sequenced behind them.

Validation: Data integrity and consistency checks are performed, adherence to RTO/RPO targets is verified, and executive approval is obtained before full production restoration.

5. Roles and Responsibilities

Role	Responsibility
Executive Sponsor	Approves major recovery decisions and resource allocation
Disaster Recovery Coordinator	Leads DR execution and coordination
IT Systems Lead	Oversees technical recovery and validation
Backup and Data Recovery Lead	Manages backup integrity and restoration processes
Communications Lead	Coordinates internal and external communications

6. Business Continuity Plan

The BCP complements the DRP by focusing on people, processes, and operational continuity rather than technical restoration alone. Critical business functions covered include payment processing and transaction handling, customer account access and support, financial reporting and regulatory submissions, and security monitoring and incident response.

Strategy	Description
Remote Work Enablement	Pre-defined remote work procedures, secure VPN with MFA, hardened managed endpoints
Manual Workarounds	Temporary manual controls for critical financial operations with defined reconciliation processes
Alternate Operating Model	Cloud-based collaboration platforms enabling fully remote operation if facilities are unavailable

7. Testing and Maintenance Schedule

Test Type	Purpose	Frequency	Owner
Tabletop Exercise	Validate roles, decision-making, and communication workflows	Semiannual	Disaster Recovery Coordinator
Backup Restore Test	Validate backup integrity and data restorability	Monthly	Backup and Data Recovery Lead
Technical Simulation	Validate system recovery procedures and technical workflows	Semiannual	IT Systems Lead
Full Failover Test	Validate end-to-end disaster recovery capability	Annual	IT Infrastructure & Exec. Leadership
Communication Test	Validate alerting, escalation, and notification processes	Quarterly	Communications Lead

Post-test activities include documenting results and observed gaps, capturing lessons learned, updating the DRP, BCP, and operational runbooks accordingly, and reporting outcomes to executive leadership.

8. Business Impact

This integrated DRP and BCP reduces downtime for critical financial services, protects sensitive customer and financial data, supports regulatory compliance across GLBA, PCI DSS, and FFIEC frameworks, and improves organizational resilience against both cyber and environmental disruptions.